

TALLER PRÁCTICO: MODELADO DE AMENAZAS Y CIBERRESILIENCIA

Proyecto Anual: Aplicación Web para el Hospital de Clínicas - V3

1. Introducción y Contexto del Proyecto

Su aplicación web para el Hospital de Clínicas de Montevideo cumple dos funciones críticas en la operativa de salud: 1) Digitalización y visualización de información de pacientes (antes entregada en papel) mediante acceso rápido con códigos QR, junto con un módulo de encuestas de satisfacción. 2) Sistema logístico y de gestión de ambulancias (trazado de recorridos en tiempo real, ubicación, choferes asignados, número de unidades y datos básicos del paciente en traslado).

Aunque este sistema no administra la historia clínica completa en un servidor de consulta interna, maneja datos sensibles de tránsito público (ubicación de vehículos de emergencia, información médica visualizada vía QR y datos de choferes). Basados en la normativa de ciberseguridad de Uruguay (alineada al estándar internacional NIST), dedicaremos esta clase de 90 minutos para evaluar la robustez de su propio software y preparar la defensa oral del diseño para la siguiente sesión.

Aspecto	Detalle
Cronograma:	Clase de 90 Minutos (Taller de Diseño) +
Destinatarios:	Siguiente Clase (Defensa Oral)
Metodología:	Estudiantes del Proyecto de Ciberseguridad (Hospital de Clínicas) Trabajo en Equipos de Proyecto

2. Consigna del Taller (Hoy: 90 minutos de diseño técnico)

Trabajando en sus equipos de proyecto durante el transcurso de esta clase, deben resolver y documentar los siguientes puntos:

Parte A: Modelado de Amenazas Específicas (45 minutos)

Analicen detalladamente los riesgos asociados a los módulos que están desarrollando:

1. Módulo de Códigos QR y Encuestas: ¿Qué pasaría si un atacante manipula físicamente los códigos QR del hospital pegando stickers propios para redirigir a los pacientes a un sitio web falso (QRishing)? ¿Cómo evitan que el módulo de encuestas sea sabotado o saturado con miles de respuestas falsas (spam)?
2. Módulo de Ambulancias (Logística): Si un atacante vulnera la base de datos o intercepta la API de localización, ¿podría rastrear la ubicación de las ambulancias en tiempo real,

alterar los recorridos asignados o conocer la identidad del chofer y del paciente en traslado? ¿Qué impacto operativo y de reputación causaría al hospital?

3. Privacidad y Datos Personales (Uruguay): Identifiquen qué datos de su aplicación están protegidos por la Ley de Protección de Datos Personales de Uruguay y requieren un cifrado o tratamiento seguro.

Parte B: Diseño de Controles de Ciberseguridad (45 minutos)

Diseñen e incorporen conceptualmente a su arquitectura técnica los siguientes controles de seguridad:

- Controles Preventivos: ¿Cómo evitarán la manipulación de la visualización del QR? (Ej. Firmas digitales en las URLs de los QR, validación de autenticidad, HTTPS obligatorio, límites de peticiones (Rate Limiting) en las encuestas para evitar spam). ¿Cómo protegerán las credenciales de acceso de los choferes?
- Controles Detectivos (Trazabilidad): Diseñen la estructura exacta de un log de auditoría para el módulo de ambulancias. ¿Qué campos debe registrar este log para rastrear cuándo y qué usuario modificó el recorrido de una ambulancia o el chofer asignado? (Ej. ID_Ambulancia, Usuario_Editor, IP, Timestamp, Recorrido_Anterior, Recorrido_Nuevo).
- Controles Correctivos (Ciberresiliencia): Si el servidor de mapas o geolocalización de las ambulancias se cae (pérdida de disponibilidad), ¿cuál es el plan de contingencia técnico de su aplicación para que el hospital siga conociendo el estado y destino de los traslados?

3. Consigna para la Siguiente Clase: Defensa Oral por Equipos

En la próxima sesión de clase, cada equipo deberá realizar una defensa oral de su diseño de seguridad frente al resto del grupo. Las condiciones de la presentación son las siguientes:

- Duración de la presentación: Máximo 5 minutos por equipo, seguidos de una ronda rápida de preguntas.
- Formato libre: Pueden utilizar diapositivas, diagramas de flujo de datos, maquetas de su base de datos o el código directo que están programando.
- Foco de la defensa: Deberán explicar con claridad el riesgo más crítico identificado en el módulo QR o de ambulancias y justificar cómo el código que están escribiendo impedirá técnicamente que ocurra un desastre.
- Participación: Todos los integrantes del equipo de proyecto deben tener un rol activo durante la defensa oral.

4. Entregables

1. Al finalizar los 90 minutos de hoy: Entregar un bosquejo o reporte preliminar de una carilla con la matriz de riesgos y los controles de seguridad diseñados.
2. En la siguiente clase: Exposición oral grupal basada en las soluciones técnicas de su proyecto.